

Cyber Threat Intelligence

Executive Briefing

Report Date: July 05, 2026

Generated: 2026-07-05 22:09 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
5	10	4	1	20

2. Executive Summary

As of July 05, 2026, the security operations center has concluded analysis on 20 distinct vulnerabilities, consisting of 5 Critical, 10 High, 4 Medium, and 1 Low severity findings. The current organizational risk posture remains elevated, characterized as Critical under CVSS v3.1 frameworks due to the prevalence of exploitable authentication and path traversal vectors. The primary threat is CVE-2026-49352, Authentication Bypass via Default JWT Secret, as it permits unauthenticated administrative access through hardcoded credentials, representing an immediate risk of system compromise. We have transitioned to a defensive posture of Immediate Remediation and Patch Deployment to mitigate these exposures. Leadership is advised that failure to address these items within the designated windows will directly expand the enterprise attack surface.

3. Critical Action List

- Execute an immediate rotational update of the 9router JWT secret and enforce mandatory service authentication resets for CVE-2026-49352 within 24 hours.
- Apply emergency security patches to the LaunchServer FileHandler to sanitize input paths for CVE-2026-54617 within 24 hours.
- Deploy session protection updates to the fast-mcp-telegram interface to remediate path traversal vulnerabilities for CVE-2026-52830 within 48 hours.
- Implement parameterized database queries for the Recce Server DuckDB interface to neutralize CVE-2026-49360 within 72 hours.
- Apply strict network isolation policies for the Steeltoe management-port to supersede Host header validation for CVE-2026-50194 within 72 hours.
- Initiate comprehensive vulnerability remediation for all remaining High-severity findings identified in the assessment cycle within 7 days.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-49352	Authentication Bypass via Default...	9.8	Critical	88/100	CWE-798
CVE-2026-54617	Path Traversal in LaunchServer Fi...	9.8	Critical	88/100	CWE-22
CVE-2026-52830	Path Traversal in fast-mcp-tegr...	9.4	Critical	85/100	CWE-22
CVE-2026-49360	SQL Injection in Recce Server Duc...	9.8	Critical	79/100	CWE-73
CVE-2026-50194	Host Header Isolation Bypass in S...	8.2	High	74/100	CWE-288
CVE-2026-2092	Unauthorized SAML Assertion Acces...	7.7	High	69/100	CWE-1287
CVE-2026-49353	Host Header Bypass in 9router Acc...	9.8	Critical	68/100	CWE-290
CVE-2026-46599	Resource Exhaustion in golang.org...	7.5	High	68/100	CWE-770
CVE-2026-52792	Source Disclosure via NTFS Filena...	7.5	High	68/100	CWE-69
CVE-2026-50200	Connection String Exposure in Ste...	7.5	High	68/100	CWE-200
CVE-2026-50196	Registry Poisoning in Steeltoe Eu...	7.5	High	68/100	CWE-20
CVE-2026-49289	XPath DoS in SimpleSAMLphp	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Misbehavior in Zebra Addr...	7.5	High	68/100	CWE-617
CVE-2026-52834	Integer Overflow in jxl-grid on 3...	8.6	High	66/100	CWE-122
CVE-2026-49284	SAML Authentication Bypass in Sim...	7.5	High	64/100	CWE-345
CVE-2026-50201	Excessive Permissions on Sensitiv...	6.5	Medium	59/100	CWE-269
CVE-2026-50202	Static JWKS Cache Poisoning in St...	5.9	Medium	53/100	CWE-668
CVE-2026-49292	Insecure Access to Kiwi TCMS Data...	6.5	Medium	48/100	CWE-862
CVE-2026-50267	Unprotected TLS Private Keys in /...	4.7	Medium	42/100	CWE-312
CVE-2026-50268	Insecure PKCS#1 v1.5 Padding in S...	1.9	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49352

Finding: Authentication Bypass via Default JWT Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1550, T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

9router utilizes a hardcoded, publicly known default JWT secret for authentication token signing. This configuration error prevents the system from effectively validating the authenticity of user sessions. An unauthenticated attacker can forge valid authentication tokens to assume any user role within the system.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the 9router authentication mechanism. The attacker retrieves the well-known hardcoded secret used for JWT signing. By creating a custom JWT signed with this secret, the attacker crafts a forged administrative session token. The server accepts the forged token, granting the attacker full access to the administrative dashboard.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: Path Traversal in LaunchServer File Handler

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1190, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The FileServerHandler in LaunchServer fails to correctly sanitize file path inputs provided by the user. An unauthenticated attacker can use directory traversal sequences to access files outside the intended web root. This flaw leads to unauthorized disclosure of sensitive system configuration files.

Proof of Concept (PoC):

An unauthenticated remote attacker constructs a HTTP request with directory traversal sequences such as .././etc/passwd. The request is sent to the LaunchServer file handling endpoint. The server, failing to validate the path, opens the requested sensitive file. The content of the sensitive file is then returned in the HTTP response.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Path Traversal in fast-mcp-telegram Session Protection

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official
MITRE ATT&CK: T1083, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram implementation of Bearer token validation permits path traversal sequences, bypassing intended session isolation. This vulnerability occurs because the token validation path does not normalize the input before accessing filesystem-backed session files. An unauthenticated attacker can manipulate token paths to hijack existing Telegram session contexts.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request to the fast-mcp-telegram API with a bearer token containing traversal sequences such as ../../sessions/admin. The server processes the path without normalization and accesses a session file outside the protected directory. The attacker successfully loads the victim's session context into their own client. This results in complete hijacking of the Telegram session.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-49360

Finding: SQL Injection in Recce Server DuckDB Handler

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 79/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server's database interface improperly handles input when interacting with the DuckDB engine, leading to unauthenticated SQL execution. This vulnerability stems from a lack of input sanitization when processing local file read/write commands via the database interface. Successful exploitation allows an unauthenticated remote attacker to gain arbitrary file system access on the host server.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the Recce server management endpoint. The attacker sends a crafted POST request containing malicious SQL syntax within the DuckDB integration parameters. The backend process executes the unsanitized SQL, allowing the attacker to interact with the local file system. This results in the potential for unauthorized data exfiltration or system file manipulation.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-50194

Finding: Host Header Isolation Bypass in Steeltoe

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe fails to enforce strict management-port isolation, relying on Host header evaluation which can be spoofed. This architectural weakness allows an unauthenticated attacker to redirect traffic intended for the management interface. An attacker can access sensitive management endpoints that should be isolated to different network segments.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request to the application port while injecting a custom Host header matching the management-side domain. The Steeltoe application routes the request to the internal management port, bypassing intended isolation. The attacker accesses diagnostic endpoints like /env or /heapdump. This allows the attacker to compromise system configuration and secrets.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092

Finding: Unauthorized SAML Assertion Access in Keycloak

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Keycloak fails to correctly validate the integrity of encrypted SAML assertions during the authentication process. The flaw is rooted in an improper validation logic check when handling encrypted XML payloads. This allows a remote attacker with limited privileges to bypass access controls and potentially impersonate other users.

Proof of Concept (PoC):

An authenticated user with low privileges submits a crafted encrypted SAML assertion to the Keycloak authentication

endpoint. The server fails to perform a rigorous validation check on the decrypted assertion structure. The system accepts the assertion as legitimate despite the internal inconsistencies. The attacker gains elevated privileges within the scope of the target application.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: Host Header Bypass in 9router Access Control

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1133, T1071

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The 9router application exhibits a flawed access gate mechanism that relies on the Host header for security context enforcement. The vulnerability arises because the router fails to strictly validate the Host header against the internal routing table, allowing spoofed requests to reach restricted local resources. This enables an unauthenticated attacker to bypass network boundary controls and access administrative functions.

Proof of Concept (PoC):

An unauthenticated remote attacker initiates a request to the 9router infrastructure. The attacker crafts an HTTP request modifying the Host header to match an internal-only domain name. The router fails to verify the request origin and grants access to the restricted internal gate. This permits the attacker to bypass authentication and execute privileged management commands.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: Resource Exhaustion in golang.org/x/image/tiff

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None

Integrity Impact

None

Availability Impact

High

Description:

The PackBits decompression routine within golang.org/x/image/tiff fails to enforce strict limits on resource allocation during image decoding. Improper handling of malformed input streams allows a small payload to trigger excessive memory or CPU usage. This vulnerability can be exploited by an unauthenticated attacker to cause a denial-of-service condition on the server.

Proof of Concept (PoC):

An unauthenticated remote attacker uploads a crafted TIFF image to the target application. The application processes the image using the vulnerable golang.org/x/image/tiff decoder. The PackBits routine attempts to allocate excessive memory based on the header metadata. The service crashes or becomes unresponsive due to memory exhaustion.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

CVE-2026-52792**Finding: Source Disclosure via NTFS Filename in Algernon**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1083, T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Algernon web server on Windows allows source code disclosure due to the way it handles specific NTFS alternate data streams or filename conventions. The vulnerability occurs when the server fails to distinguish between executable script content and accessible file resources when provided with specific filename patterns. This leads to the exposure of server-side script source code.

Proof of Concept (PoC):

An unauthenticated remote attacker requests a script file path appended with specific NTFS-specific filename characters. The Algernon server interprets the input incorrectly and bypasses the execution logic, instead serving the raw content of the file. The script source code is returned to the client browser. This results in the loss of proprietary intellectual property and potential secrets embedded in the code.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>

CVE-2026-50200**Finding: Connection String Exposure in Steeltoe Actuators**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe environment sanitizer fails to filter embedded database connection strings from the /env actuator response. This flaw results in the clear-text leakage of sensitive credentials when diagnostic information is accessed. An unauthenticated remote attacker can exploit this to obtain database access credentials.

Proof of Concept (PoC):

An unauthenticated remote attacker navigates to the /env endpoint of a Steeltoe application. The application returns the full environment dump, including unmasked database connection strings. The attacker parses the response to retrieve DB username and password combinations. This results in total compromise of the back-end database.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Registry Poisoning in Steeltoe Eureka Discovery

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Steeltoe's Discovery.Eureka client fails to properly validate the DataCenterInfo.Name attribute when parsing service registry responses. An attacker can inject malformed input to cause parsing failures that impact the entire registry fetch process. This allows for a service-wide denial-of-service condition affecting service discovery.

Proof of Concept (PoC):

An unauthenticated remote attacker compromises a service registration node and sends a malicious service entry with a specially crafted DataCenterInfo.Name. The Steeltoe client receives this entry and encounters a fatal exception during the parsing logic. The registry fetch process terminates, preventing all instances from discovering each other. This results in a complete service discovery outage.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: XPath DoS in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial-of-service attack due to complex XPath transformation processes used during XML signature verification. The vulnerability exists when the XML processor is forced to evaluate deeply nested or highly recursive XPath expressions. This allows an attacker to consume excessive CPU resources through specially crafted XML payloads.

Proof of Concept (PoC):

An unauthenticated remote attacker submits a crafted SAML Request containing an XML payload with multiple nested XPath expressions. SimpleSAMLphp attempts to process the verification while the XML engine enters a computational loop. System CPU usage spikes to 100%, causing the server to become unresponsive to legitimate authentication requests.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Misbehavior in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Zebra Address Book service triggers an assertion failure when handling misaligned or specifically formatted IPv4-mapped addresses within the memory pool manager. This occurs because the memory allocator does not correctly validate the bounds of address structures prior to storage. This leads to process aborts, causing a denial-of-service

condition.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a network packet containing a maliciously formatted IPv4-mapped address to the Zebra service. The service's memory manager attempts to process the address and triggers an assertion failure due to length mismatch. The application process terminates immediately, leading to a denial-of-service for all address book functions.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>

CVE-2026-52834

Finding: Integer Overflow in jxl-grid on 32-bit Systems

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The jxl-grid library exhibits an integer overflow vulnerability when calculating buffer sizes for image processing on 32-bit platforms. This defect causes the library to allocate insufficient memory during data decompression, leading to out-of-bounds write operations. An attacker can exploit this to corrupt memory or gain remote code execution.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specifically crafted image containing extreme dimensions to a 32-bit host running jxl-grid. The library attempts to allocate a buffer based on the malicious dimensions, triggering an integer overflow. The resulting small buffer leads to an out-of-bounds write as the library attempts to decompress the image data. This results in process memory corruption and potential code execution.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

CVE-2026-49284

Finding: SAML Authentication Bypass in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
---------------	---------

Attack Complexity	High
-------------------	------

Privileges Required	None
Scope	Unchanged
Integrity Impact	High

User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The SimpleSAMLphp Service Provider (SP) module fails to properly bind unsigned Responses to assertions when the SubjectConfirmationData lacks an InResponseTo field. This vulnerability occurs during the verification phase of the SAML handshake process. An attacker can spoof SAML responses, leading to unauthorized identity assertion.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the SimpleSAMLphp SP login flow. The attacker intercepts a valid user request and injects a crafted unsigned SAML response lacking specific integrity markers. The SP fails to link the assertion correctly and accepts the fraudulent response as valid. The attacker is subsequently logged into the application as the target user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>

CVE-2026-50201

Finding: Excessive Permissions on Sensitive Actuators

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269

Score Provenance: CNA Official

MITRE ATT&CK: T1592, T1082

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe exposes management actuators such as /heapdump and /env to users with only 'Restricted' privileges. This excessive permission assignment allows users to view sensitive system diagnostic information. An attacker can leverage this data to map the internal system environment and discover secret values.

Proof of Concept (PoC):

An authenticated user with low privileges requests the /heapdump endpoint on the target Steeltoe instance. The system processes the request despite the user lacking administrative clearance. The user receives a full heap memory dump. This allows the attacker to extract sensitive credentials and configuration data from memory.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-50202

Finding: Static JWKS Cache Poisoning in Steeltoe

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's JSON Web Key Set (JWKS) cache is incorrectly shared across multiple authentication schemes and is never invalidated. This architectural defect allows an attacker with high privileges to inject or persist stale keys. Consequently, future authentication checks might rely on compromised or expired cryptographic material.

Proof of Concept (PoC):

A highly privileged attacker updates the central JWKS configuration via the management API. The Steeltoe application caches the malicious key across all active schemes indefinitely. New tokens signed with this key are accepted by the system. This allows the attacker to maintain persistent, unauthorized access to the application.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-49292

Finding: Insecure Access to Kiwi TCMS Database Init

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Kiwi TCMS /init-db/ page remains active and responsive to requests after the initial database configuration has occurred. This administrative oversight permits unauthorized users to interact with the database initialization logic. An unauthenticated attacker could potentially exploit this to disrupt service or gain insights into the database schema.

Proof of Concept (PoC):

An unauthenticated remote attacker navigates to the /init-db/ endpoint on a production Kiwi TCMS instance. The server processes the request despite the application already being initialized. The attacker receives a response containing database initialization status or configuration details. This results in the exposure of sensitive system state information.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

CVE-2026-50267

Finding: Unprotected TLS Private Keys in /tmp

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe fails to manage TLS private key files properly, writing them to a shared /tmp directory with default world-readable permissions and failing to delete them after use. This information disclosure vulnerability stems from poor file lifecycle management in the TLS credential provider. A local attacker can read these keys to perform unauthorized decryption.

Proof of Concept (PoC):

A local user on the host system monitors the /tmp directory during application startup. The attacker identifies a newly created file containing a TLS private key. The attacker copies the private key file before the application can delete it. This enables the attacker to decrypt encrypted traffic captured from the network.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-50268

Finding: Insecure PKCS#1 v1.5 Padding in Steeltoe

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local
Privileges Required	High
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Steeltoe framework incorrectly defaults to PKCS#1 v1.5 padding even when the configuration is explicitly set to OAEP. This cryptographic flaw arises from an internal configuration mismatch in the TLS/encryption stack. Although exploitation requires high-privileged access, the weakness reduces the cryptographic strength of the protected data.

Proof of Concept (PoC):

A local attacker with high administrative privileges gains access to the application server. The attacker observes the

encryption configuration and identifies that the padding is silently downgraded to PKCS#1 v1.5 despite settings. The attacker then mounts a chosen-ciphertext attack against the encrypted data. The compromise results in the reduction of security assurance for encrypted transit channels.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>